# VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

EARTH CTF — Authorized Lab Assessment

| | |
|---|---|
| **Victim hostname** | earth.local / earth.lan; terratest.earth.local observed as a related virtual host |
| **Victim IP** | 192.168.31.53 |
| **Assessment platform** | Kali Linux against an intentionally vulnerable CTF machine |
| **Assessment date** | 14 October 2026 (report preparation date; screenshots are dated July 2026) |
| **Scope** | Victim host only; other discovered IPs, hostnames, and device names are redacted or omitted |

**Confidentiality / redaction note.** This report retains only the victim identity. Unrelated network hosts, callback addresses, and unrelated personal/business data have been omitted or redacted. The restaurant onboarding screenshot containing tax/bank information was excluded entirely.

# 1. Executive Summary

The screenshots document an assessment of the Earth Secure Messaging Service. The victim was identified as **192.168.31.53**, with HTTP/HTTPS virtual hosts **earth.local** and **terratest.earth.local**. Observed services include SSH on TCP/22, HTTP on TCP/80, and HTTPS on TCP/443. Web enumeration exposed an administrative path, a robots.txt file that disallows testingnotes.*, and a testing notes file containing implementation/security clues. The evidence then shows a command execution path that yields a shell as the Apache service account, followed by a reset_root trigger and successful root access/root-flag retrieval.

Overall impact: **Critical in the isolated CTF environment**, because the captured sequence reaches root. This rating is specific to the intentionally vulnerable lab and is not a statement about any production deployment.

# 2. Scope and Method

Scope was restricted to the victim IP and associated web virtual hosts evidenced in the screenshots. Methods shown include host/service discovery, Nmap service/script enumeration, directory discovery with Gobuster, manual review of robots.txt and text files, analysis of an XOR-encoded message, and validation of command execution and privilege escalation in the CTF.

# 3. Observed Service Map

| Port | Observed service | Evidence / interpretation |
|---|---|---|
| 22/TCP | SSH — OpenSSH 8.6 | Open; no SSH-specific exploit is demonstrated in the screenshots. |
| 80/TCP | HTTP — Apache 2.4.51 (Fedora), mod_wsgi 4.7.1, Python 3.9 | Open; web app titled Earth Secure Messaging Service. |
| 443/TCP | HTTPS — Apache 2.4.51; TLS certificate presented | Certificate dates shown as 2021-10-12 to 2022-10-10; expired at assessment evidence time. Verify system time and certificate chain. |

Note: only these three ports are shown as open in the target-specific scan. The subnet discovery screenshot contained unrelated hosts; those details are not reproduced.

# DETAILED PROOF OF CONCEPT (PoC)

This section expands the summary into reproducible, evidence-linked steps in the style of the supplied Kioptrix report. Run commands only in the isolated Earth CTF lab. Victim identity retained: 192.168.31.53 / earth.local. Other discovered hosts and callback IPs are intentionally omitted.

## PoC-01 — Target service discovery and port inventory

**Objective:** confirm the three open TCP ports shown in the target-specific Nmap screenshots.

**Steps:** (1) Ensure the CTF victim is powered on and the lab network is isolated. (2) Scan only the victim. (3) Record state, service and version; compare with Evidence B/C in the appendix.

```
nmap -sV -sC -Pn -p 22,80,443 192.168.31.53
```

**Observed:** TCP/22 SSH (OpenSSH 8.6), TCP/80 HTTP (Apache 2.4.51 / mod_wsgi / Python 3.9), TCP/443 HTTPS (Apache 2.4.51). No direct SSH exploit is demonstrated; exposure/version identification alone is informational.

## PoC-02 — TCP/22 SSH service enumeration

**Objective:** validate SSH reachability and banner information without attempting password guessing.

```
nmap -sV -Pn -p 22 192.168.31.53
nc -nv 192.168.31.53 22
```

**Evidence/result:** Nmap identifies OpenSSH 8.6. The screenshots do not demonstrate a successful SSH login or a specific SSH CVE, so do not claim SSH compromise. **Remediation:** patch OpenSSH, prefer keys/MFA, rate-limit authentication and restrict SSH to trusted management hosts.

## PoC-03 — TCP/80 HTTP service and web application

```
curl -i http://earth.local/
curl -I http://earth.local/
```

**Observed:** the browser shows “Earth Secure Messaging Service”. Nmap reports Apache 2.4.51, mod_wsgi/Python details, and GET/HEAD/OPTIONS. Version disclosure alone does not prove a specific exploitable CVE. **Remediation:** patch components, disable unnecessary modules/methods and review access controls.

## PoC-04 — TCP/443 HTTPS certificate validation

```
nmap -Pn -p 443 --script ssl-cert 192.168.31.53
openssl s_client -connect 192.168.31.53:443 -servername earth.local </dev/null
```

**Observed:** Nmap's certificate output shows validity ending 2022-10-10. Verify the target clock and current certificate before finalizing severity; this evidence alone does not prove weak ciphers. **Remediation:** renew using a trusted CA, match SAN to hostname and automate renewal.

# PoC-05 — Web directory and virtual-host discovery

**Objective:** reproduce directory enumeration and validate the files shown in the screenshots.

```
gobuster dir -u http://earth.local -w /usr/share/wordlists/dirb/common.txt
gobuster dir -k -u https://terratest.earth.local -w /usr/share/wordlists/dirb/common.txt
curl -k -i https://terratest.earth.local/robots.txt
curl -k -i https://terratest.earth.local/testingnotes.txt
```

**Steps:** enumerate common paths; manually review the admin redirect and cgi-bin response; then request robots.txt and testingnotes.txt on the related virtual host. **Observed:** admin redirects, cgi-bin returns 403, and the related host exposes robots.txt/testingnotes.txt. Notes disclose a `terra` admin username and implementation details. robots.txt is not access control; 403 alone is not a vulnerability.

**Remediation:** remove developer/test files from web roots and enforce authentication/authorization on admin routes and sensitive resources.

# PoC-06 — Message decoding and XOR weakness

**Objective:** validate the weakness shown by the supplied CyberChef screenshots without assuming details not in evidence.

**Steps:** (1) Retrieve testdata.txt from the authorized virtual host. (2) Copy the hex payload into CyberChef/local decoder. (3) Apply “From Hex”, then XOR with the key text shown in the testing notes. (4) Inspect the decoded output for repeated predictable plaintext.

```
curl -k -i https://terratest.earth.local/testdata.txt
```

**Observed:** the supplied workflow yields repeated plaintext similar to `earthclimatechangebad4humans...`, consistent with a predictable/reused key or weak custom scheme. **Remediation:** replace custom XOR with authenticated encryption such as AES-GCM or ChaCha20-Poly1305, unique nonces, secure key management and rotation.

# PoC-07 — Admin Command Tool: server-side command execution

**Objective:** validate the admin page's return of operating-system command output. Use only the intentionally vulnerable lab.

**Steps:** (1) Open the admin command tool at the route discovered in the lab. (2) Enter a benign diagnostic command. (3) Submit and record output. The supplied screenshot shows `ls -la` output returned in the page; subsequent evidence shows a shell running as Apache.

```
id
whoami
pwd
```

**Observed:** command output is rendered by the web page, supporting server-side command execution. The exact source line/input primitive is not supplied, so this report describes observed behavior rather than asserting a specific injection type.
**Remediation:** remove arbitrary shell execution; replace it with fixed allowlisted operations, strong authorization and audit logging.

## PoC-08 — Shell identity and impact boundary

**Evidence:** screenshots show a listener/session and `whoami` returning `apache`, with `id` showing uid/gid 48. Non-victim callback addresses are redacted. This proves execution as the web-server account, not root by itself.

```
whoami
id
```

**Remediation:** least-privilege service account, outbound connection restrictions, process isolation and monitoring for unexpected shells/child processes.

# PoC-09 — reset_root privilege escalation

**Objective:** document the privilege-escalation chain visible in the supplied CTF evidence. This records the lab result; do not run against any real system.

**Evidence sequence:** (1) the shell screenshot shows trigger-file creation attempts in temporary/shared-memory locations. (2) `reset_root` reports that reset triggers are present and the root password is being reset to `Earth`. (3) the next screenshot shows `su root` succeeding. (4) the final screenshot shows a root prompt and access to `root_flag.txt`.

```
reset_root
su root
# Lab output indicates password: Earth
id
cd /root
ls -la
cat root_flag.txt
```

**Observed result:** the screenshots demonstrate root-level access within the intentionally vulnerable CTF VM and root-flag retrieval. Review the script source and file permissions to establish the exact underlying cause. **Remediation:** remove reset triggers; prevent unprivileged users invoking privileged reset logic; secure script ownership/permissions; remove hard-coded passwords; audit sudo/setuid configuration.

# PoC-10 — Finding-to-evidence summary

**TCP/22:** Nmap banner confirms SSH/OpenSSH 8.6; no exploit or login demonstrated.
**TCP/80:** Nmap and browser confirm HTTP/Apache and the Earth messaging page.
**TCP/443:** Nmap ssl-cert output shows a certificate expiry date; revalidate current certificate and clock.
**Web content:** Gobuster plus direct requests show robots.txt/testingnotes.txt and implementation notes.
**Cryptography:** hex + XOR screenshot yields repeated plaintext.
**Command execution:** Admin Command Tool displays command output and later Apache-context shell evidence.
**Privilege escalation:** reset_root output, root prompt and root flag demonstrate root access in the CTF.

Important evidence limits: service banners do not automatically prove a CVE; the certificate state should be checked live; the exact application source-code flaw is not visible in screenshots. The high-impact command-execution/root chain is directly demonstrated in the supplied CTF evidence.

# 4. Findings and Proof of Concept

Severity reflects demonstrated impact in the CTF and should be revalidated against the actual build/configuration before using this report for a real system.

## F-01 — Administrative command execution leading to root access

**Severity:** Critical (CTF impact)

**Description:** The screenshots show an Admin Command Tool accepting a CLI command, a reverse shell connected to the victim as uid=48(apache), and a reset_root trigger that resets the root password to “Earth”. A subsequent su root session and root_flag.txt output demonstrate root-level compromise in the lab. This is the primary confirmed finding.

**PoC / validation steps**

• Review the supplied admin command tool screenshot and confirm the command input is executed server-side.

• Reproduce only in the isolated CTF: use a harmless command such as `id` to confirm the execution context; do not run destructive commands.

• The captured lab chain then shows a callback shell as the Apache user, creation of the specific trigger files, execution of `reset_root`, and successful root authentication. Preserve the supplied screenshots as evidence rather than repeating the destructive chain on any non-lab system.

**Remediation:** Remove or disable the command-execution feature. If administrative commands are required, use a strict allowlist of fixed operations, avoid shell invocation, validate authorization server-side, and run the service with least privilege. Remove reset triggers and rotate credentials; review logs for command execution.

## F-02 — Web application command injection / unsafe command handling

**Severity:** Critical

**Description:** The admin page explicitly describes itself as a command tool. The evidence shows command output returned in the page and later a reverse shell from the web service account. This strongly supports unsafe server-side command execution; the exact vulnerable source line is not shown.

**PoC / validation steps**

• Open `http://earth.local/` in the lab and navigate to the discovered admin route only after authorized access.

• Use a benign command such as `id` in the provided command field. The screenshot records command output, proving server-side command execution.

• Correlate with the reverse-shell screenshot showing the resulting session as `apache`. Treat the callback address as redacted in this report.

**Remediation:** Do not pass user input to a shell. Replace shell execution with fixed server-side functions, enforce role-based authorization, validate inputs, use a restricted service account, and log all administrative actions.

## F-03 — Privilege escalation via reset_root trigger

**Severity:** Critical

**Description:** The evidence shows `reset_root` reporting that reset triggers are present and setting the root password to `Earth`; the next screenshot shows `su root` succeeding and a root prompt. This is direct evidence of privilege escalation in the CTF.

**PoC / validation steps**

• Within the supplied lab evidence, the trigger files are created under writable locations and `reset_root` is run.

• The program output states that the root password is being reset; the next screenshot shows successful root authentication.

• The root flag file is then accessed, confirming the impact. Do not repeat this procedure outside the intentionally vulnerable VM.

**Remediation:** Remove the password-reset trigger mechanism, ensure reset utilities cannot be invoked by unprivileged users, verify ownership and permissions of scripts and trigger files, and never set a known/static root password.

## F-04 — Sensitive implementation details exposed in web files

**Severity:** Medium

**Description:** Gobuster found `robots.txt` and `testingnotes.txt` on the related virtual host. The notes disclose internal implementation details, including XOR use, message key practices, and the `terra` username for the admin portal. `robots.txt` disallows testingnotes.* paths but robots directives do not provide access control.

**PoC / validation steps**

• Request `https://terratest.earth.local/robots.txt` and review the response. The screenshot shows multiple disallowed file extensions and `testingnotes.*`.

• Request `https://terratest.earth.local/testingnotes.txt`; the screenshot shows implementation notes and an admin username.

• Directory discovery also reported `index.html` and `robots.txt` with HTTP 200, while several paths returned 403. A 403 response is not itself proof of a vulnerability.

**Remediation:** Remove developer notes and sensitive files from web roots, prevent directory/file exposure, and use authentication/authorization rather than robots.txt to protect resources.

## F-05 — Weak/reused XOR message protection

**Severity:** High

**Description:** The screenshots show a long hexadecimal message decoded from hex and XORed with a text key, producing repeated plaintext `earthclimatechangebad4humans...`. This indicates repeated structure and a predictable/reused XOR key or key-derived plaintext. XOR is not suitable for protecting messages when the key is reused or weak.

**PoC / validation steps**

• Convert the captured hexadecimal payload from hex to bytes, then XOR-decode it using the key shown in the lab notes.

• The supplied CyberChef screenshot shows the decoded output repeating `earthclimatechangebad4humans`, supporting key reuse/predictability.

• Confirm this behavior with the application’s intended message format; the screenshot alone does not establish a modern cryptographic algorithm or full protocol design.

**Remediation:** Replace custom XOR encryption with a vetted authenticated-encryption scheme such as AES-GCM or ChaCha20-Poly1305. Use cryptographically random unique nonces, sound key derivation, managed key rotation, and integrity/authentication checks.

## F-06 — Expired HTTPS certificate

**Severity:** Low–Medium

**Description:** Nmap's ssl-cert output shows the certificate validity ending on 2022-10-10. The screenshot also shows a certificate subject/SAN associated with earth.local. Confirm the target system clock and current certificate before finalizing this finding.

**PoC / validation steps**

• Run a certificate-only check against the authorized victim: `nmap -Pn -p 443 --script ssl-cert 192.168.31.53`.

• Review the `Not valid before` and `Not valid after` fields in the output. The supplied evidence shows the certificate expired in 2022.

**Remediation:** Renew the certificate with a trusted CA, ensure the SAN matches the hostname, configure automatic renewal, and monitor certificate expiry.

## F-07 — Service/version disclosure on HTTP and SSH

**Severity:** Low

**Description:** Nmap identifies OpenSSH 8.6 and Apache 2.4.51 with mod_wsgi/Python version details. Version disclosure increases reconnaissance value but is not, by itself, proof that a particular CVE is exploitable.

**PoC / validation steps**

• Run `nmap -sV -Pn -p 22,80,443 192.168.31.53` against the isolated target.

• Compare returned banners with vendor package advisories and verify installed package revisions before mapping any CVE.

**Remediation:** Patch to supported vendor builds, remove unnecessary modules, minimize unnecessary banner details where practical, and restrict SSH to trusted management networks.

# 5. Additional Validation Commands

Use these commands only against the isolated Earth CTF victim you are authorized to test. They are intended for service validation and evidence reproduction, not for scanning unrelated systems.

```
nmap -sV -sC -Pn -p 22,80,443 192.168.31.53
nmap -Pn -p 443 --script ssl-cert 192.168.31.53
curl -I http://earth.local/
curl -k -i https://terratest.earth.local/robots.txt
curl -k -i https://terratest.earth.local/testingnotes.txt
```

# 6. Remediation Priority

| Priority | Action |
|---|---|
| 1 — Immediate | Remove the command execution feature and reset_root trigger; rotate root/admin credentials and review logs. |
| 2 — High | Replace custom XOR/reused-key messaging with authenticated encryption; assess whether messages or keys were exposed. |
| 3 — High | Remove developer notes and sensitive files from the web root; add authorization controls. |
| 4 — Medium | Renew HTTPS certificate and verify hostname/chain and automated renewal. |
| 5 — Routine | Patch SSH/Apache/Python components and limit service exposure to required networks. |

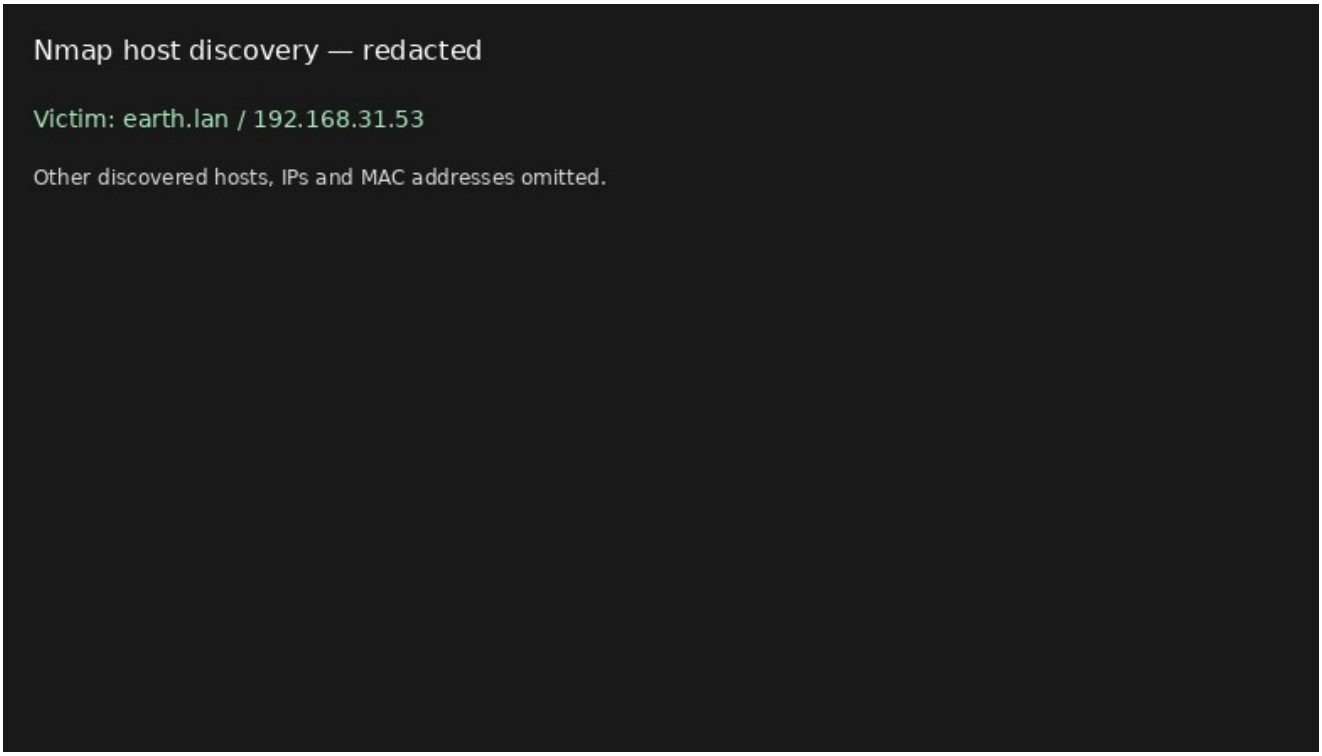
# 7. Limitations

This report is based on the supplied screenshots, not a live retest or source-code review. The evidence directly demonstrates command execution and root access in the CTF, but does not establish a specific CVE for Apache/OpenSSH, nor does it prove all possible application weaknesses. The certificate finding depends on the system clock and current certificate state. The separate restaurant onboarding screenshot was excluded because it is unrelated and contains sensitive tax/banking details.

# 8. Screenshot Evidence Appendix

Screenshots are included as supporting evidence. Unrelated discovered hosts and non-victim IPs are omitted or redacted. Evidence screenshots are resized to fit the report; command output content is otherwise retained where practical.

## Evidence A — Host discovery summary. Only the victim identity is retained.



## Evidence B — Target-specific Nmap scan: SSH, HTTP and HTTPS ports.

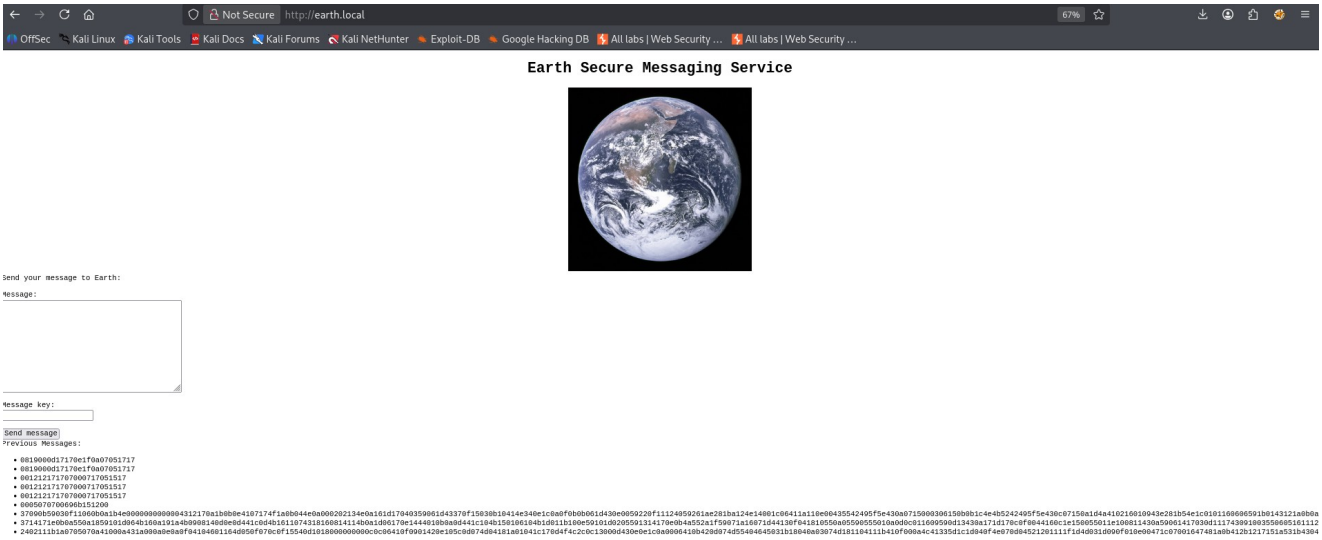
```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p-  192.168.31.53
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-11 15:03 +0500
Stats: 0:01:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 50.72% done; ETC: 15:06 (0:01:21 remaining)
Nmap scan report for earth.lan (192.168.31.53)
Host is up (0.00064s latency).
Not shown: 65367 filtered tcp ports (no-response), 165 filtered tcp ports (admin-prohibited)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 8.6 (protocol 2.0)
80/tcp  open  http     Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
443/tcp open  ssl/http Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
MAC Address: 00:0C:29:A8:15:F7 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 172.58 seconds
```

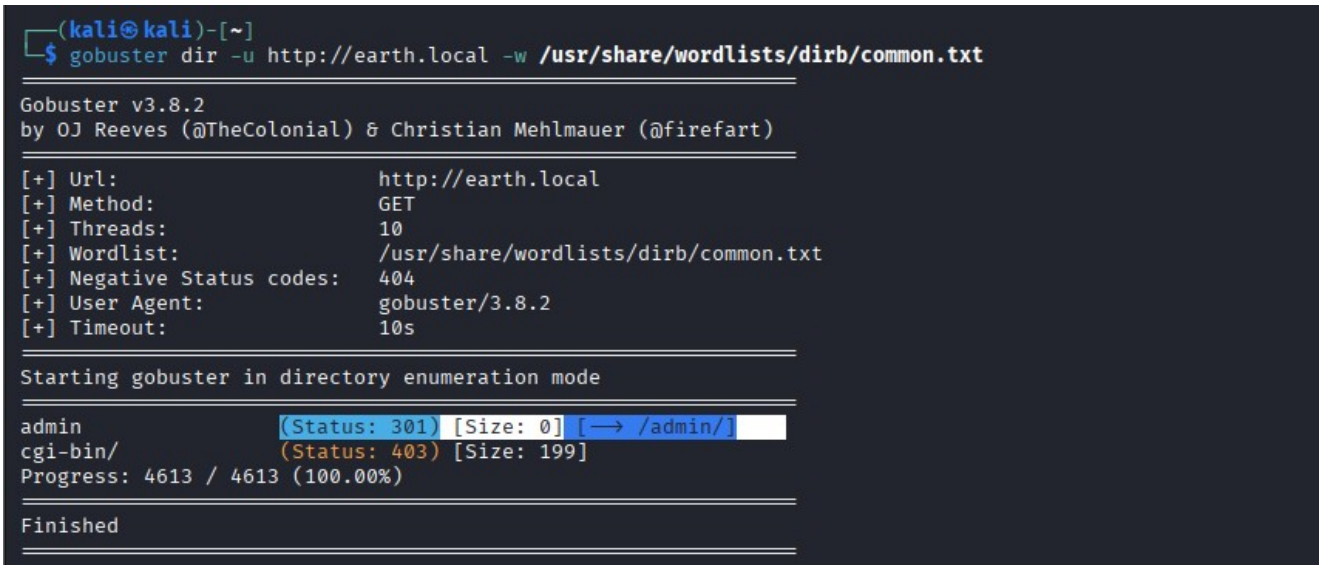
## Evidence C — Nmap service/script details and TLS certificate validity dates.

```
Not shown: 986 filtered tcp ports (no-response), 11 filtered tcp ports (admin-prohibited)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 8.6 (protocol 2.0)
| ssh-hostkey:
|   256 5b:2c:3f:dc:8b:76:e9:21:7b:d0:56:24:df:be:e9:a8 (ECDSA)
|_  256 b0:3c:72:3b:72:21:26:ce:3a:84:e8:41:ec:c8:f8:41 (ED25519)
80/tcp  open  http     Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
| http-methods:
|_  Supported Methods: GET HEAD OPTIONS
|_http-title: Earth Secure Messaging
|_http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9
443/tcp open  ssl/http Apache httpd 2.4.51 ((Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9)
| ssl-cert: Subject: commonName=earth.local/stateOrProvinceName=Space
| Subject Alternative Name: DNS:earth.local, DNS:terratest.earth.local
| Issuer: commonName=earth.local/stateOrProvinceName=Space
| Public Key type: rsa
| Public Key bits: 4096
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2021-10-12T23:26:31
| Not valid after:  2031-10-10T23:26:31
| MD5:     4efa 65d2 1a9e 0718 4b54 41da 3712 f187
| SHA-1:   04db 5b29 a33f 8076 f16b 8a1b 581d 6988 db25 7651
|_SHA-256: e85f 5eac 6004 faef 0317 41fb 8f0c 8f3c ede4 56aa f485 41ce d5c4 822d 609c 04f6
| tls-alpn:
|_  http/1.1
|_ssl-date: TLS randomness does not represent time
|_http-server-header: Apache/2.4.51 (Fedora) OpenSSL/1.1.1l mod_wsgi/4.7.1 Python/3.9
|_http-title: Earth Secure Messaging
| http-methods:
|_  Supported Methods: GET HEAD OPTIONS
```

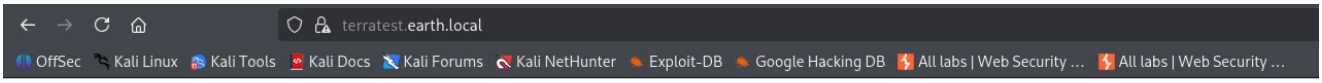
# Evidence D — Earth Secure Messaging Service web page.



## Evidence E — Gobuster results for earth.local: admin redirect and cgi-bin forbidden response.

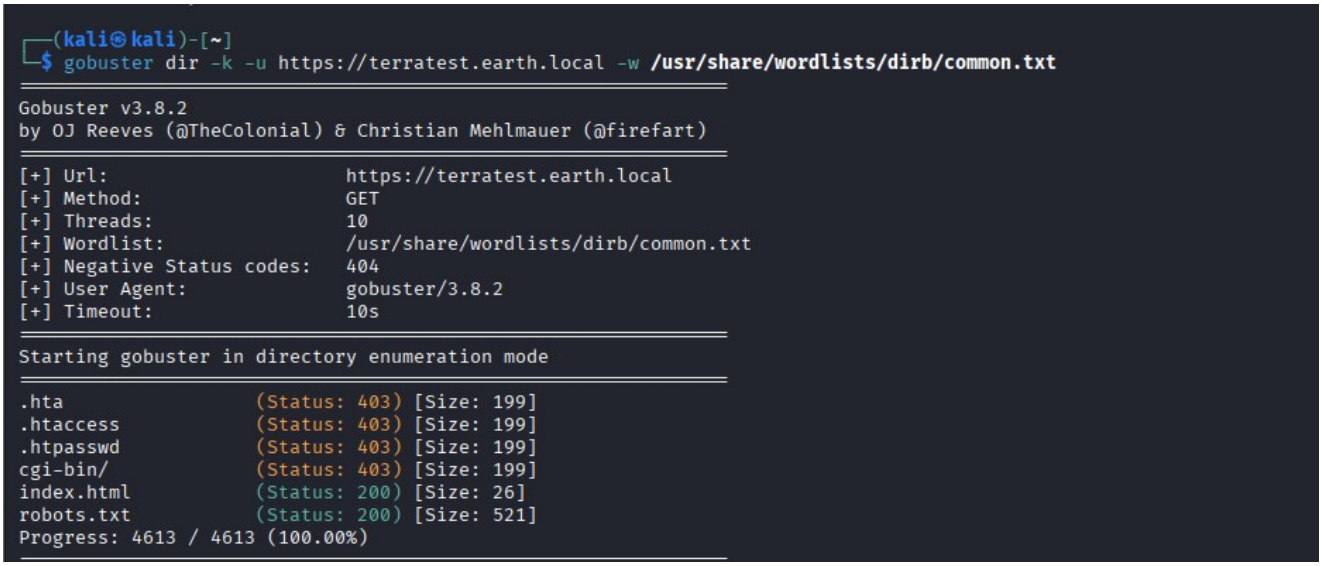


## Evidence F — Related virtual host terratest.earth.local.

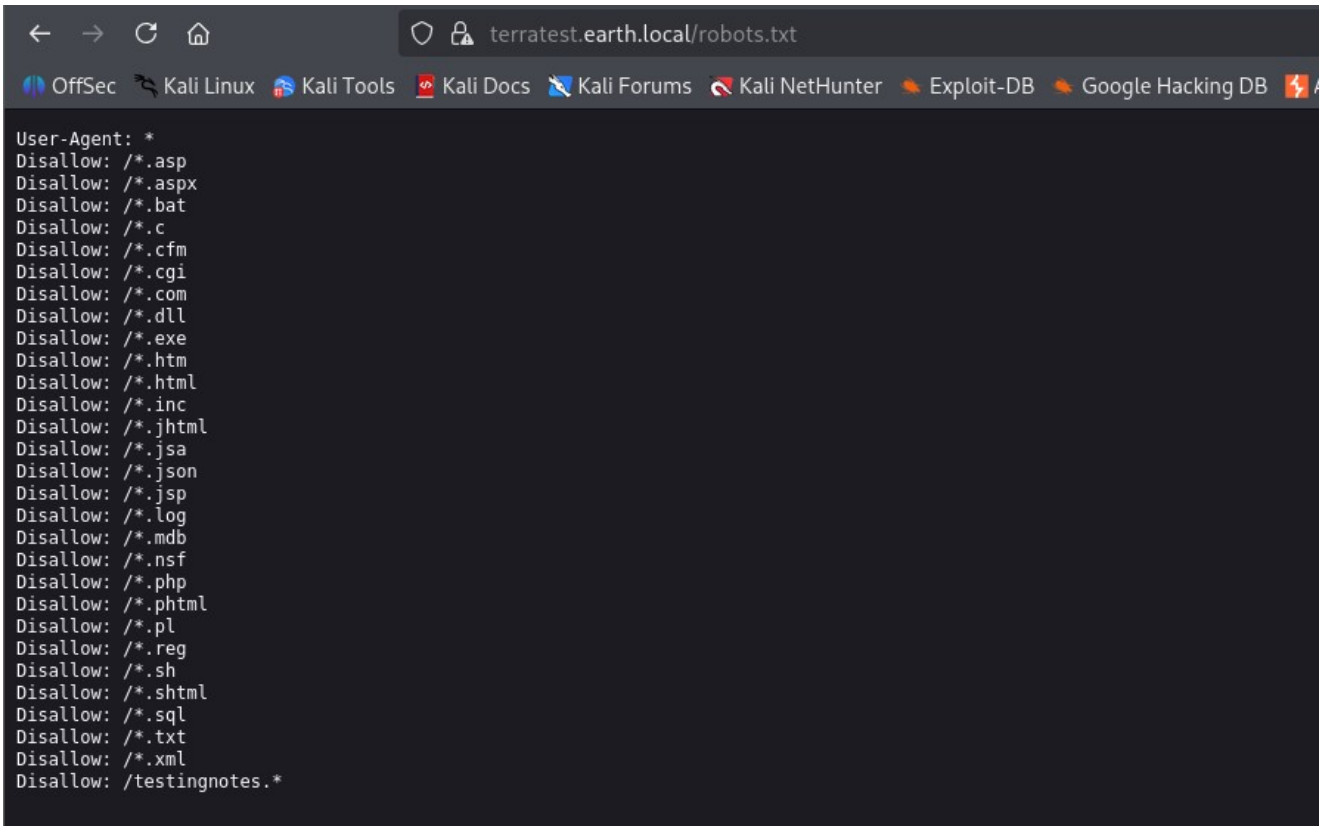



Test site, please ignore.

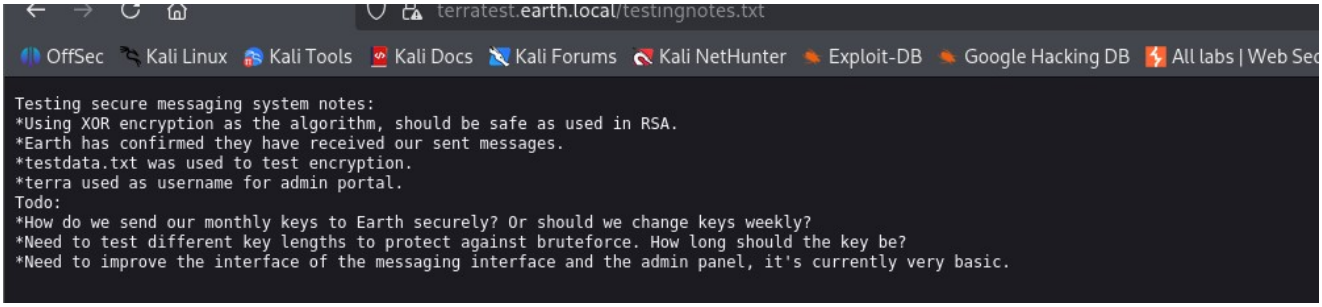
## Evidence G — Gobuster results for the related virtual host.



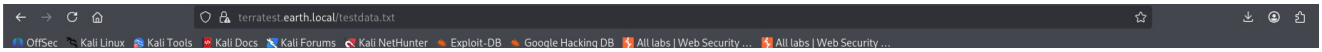
## Evidence H — robots.txt disallows testingnotes.*; robots directives are not access controls.



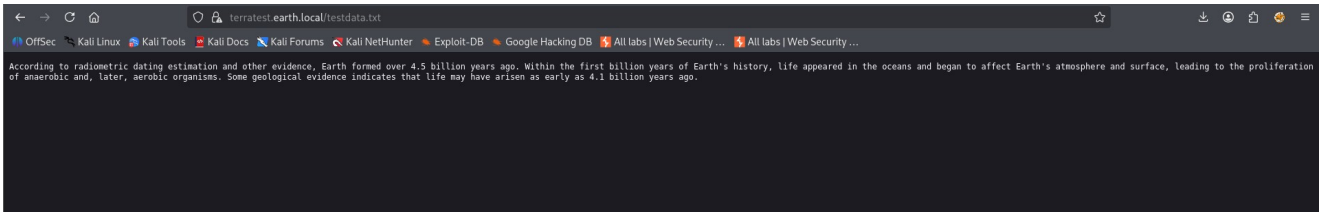
## Evidence I — testingnotes.txt exposes internal implementation/security notes.



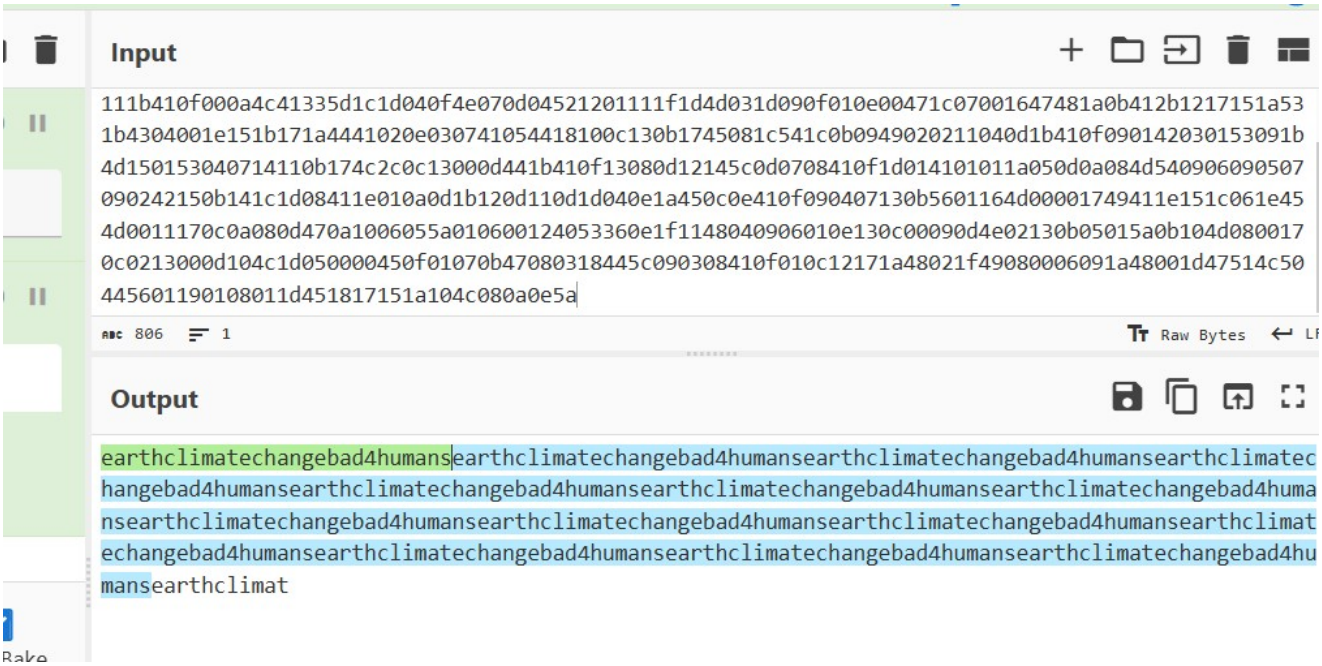
## Evidence J — testdata.txt page.



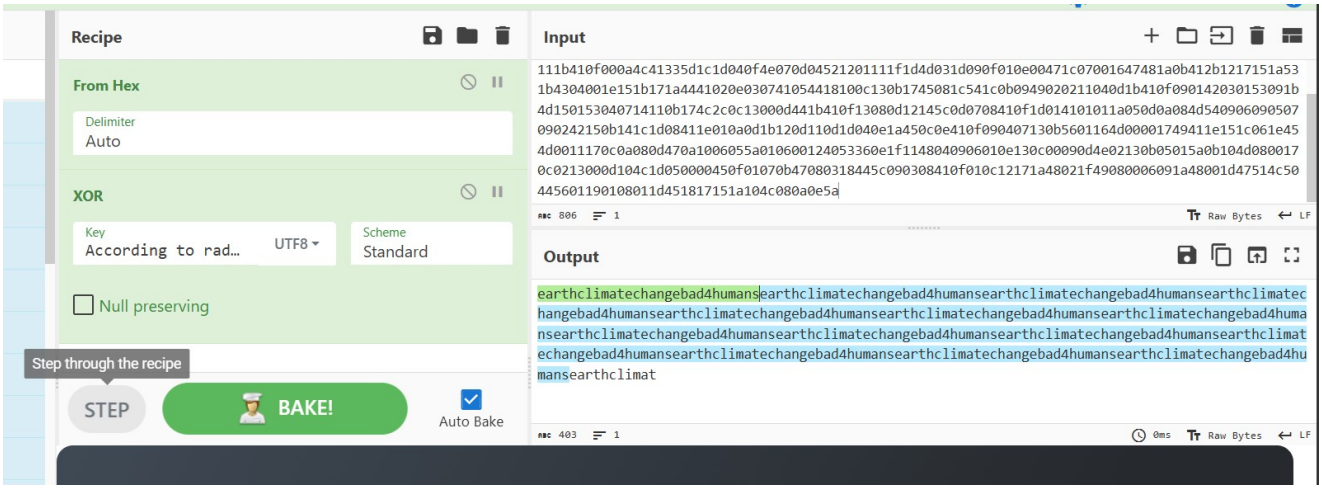
## Evidence K — testdata.txt content.



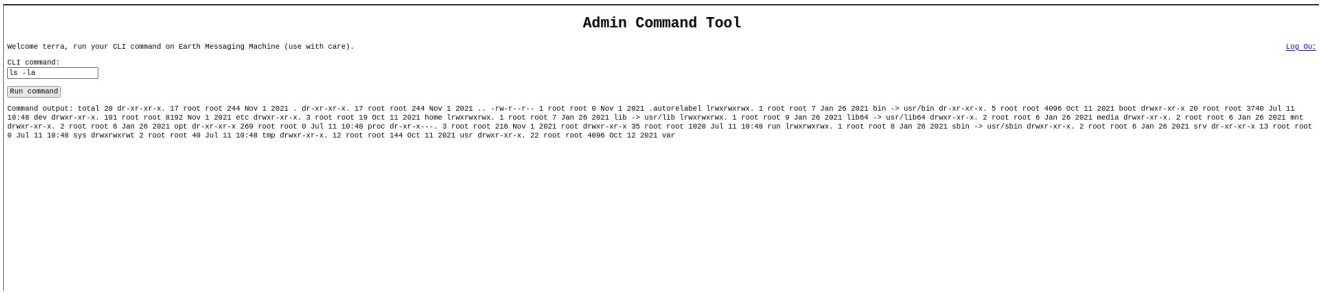
## Evidence L — Hex-to-bytes and XOR decoding output.



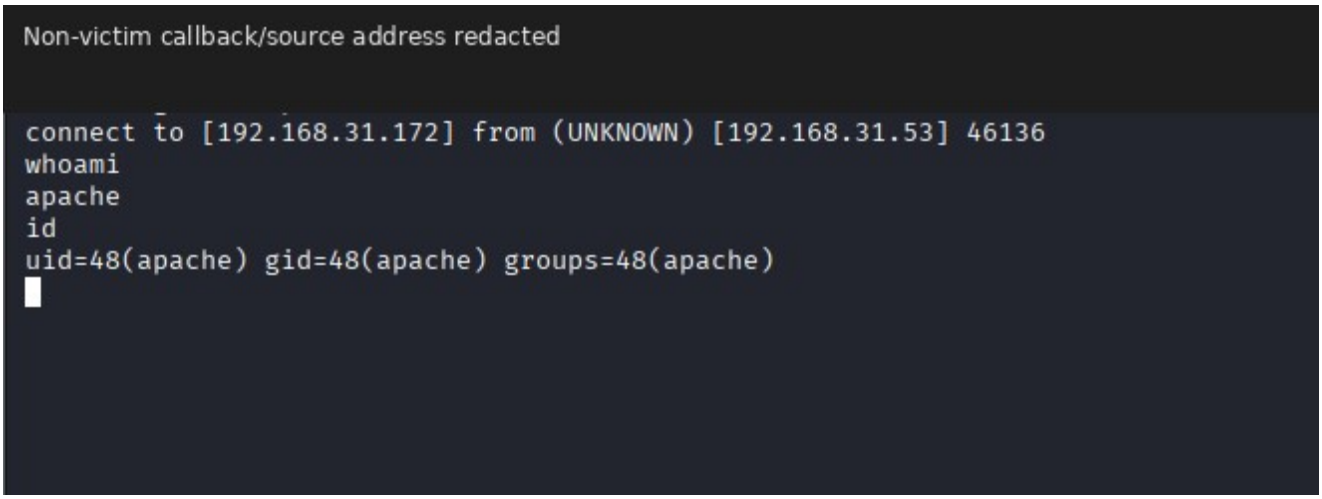
## Evidence M — XOR recipe configuration and repeated plaintext.



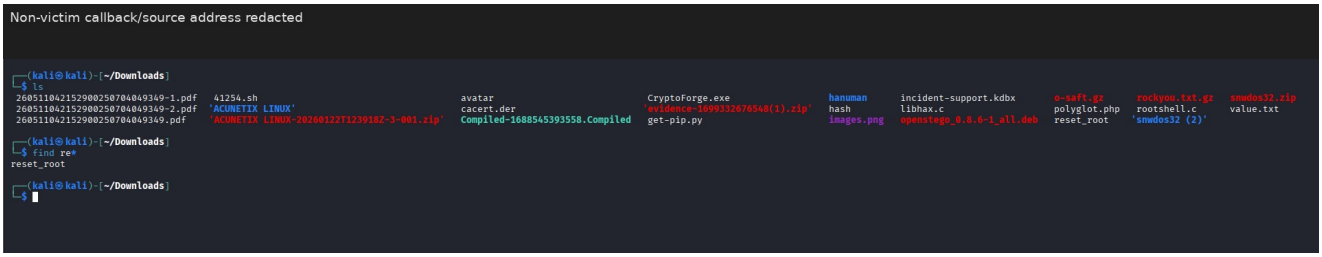
# Evidence N — Admin Command Tool returns command output.



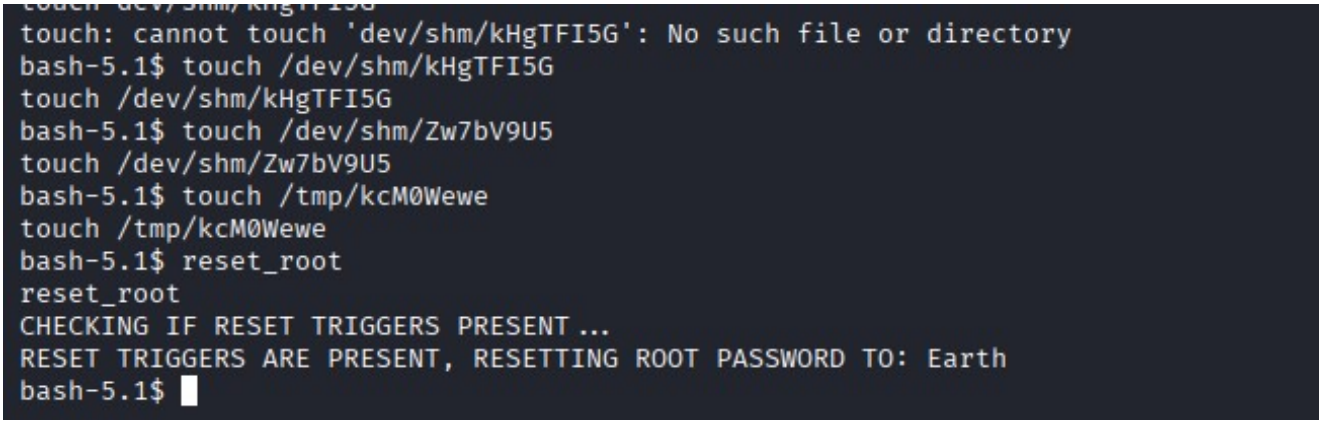
## Evidence O — Reverse shell session as the Apache service account; callback address redacted.



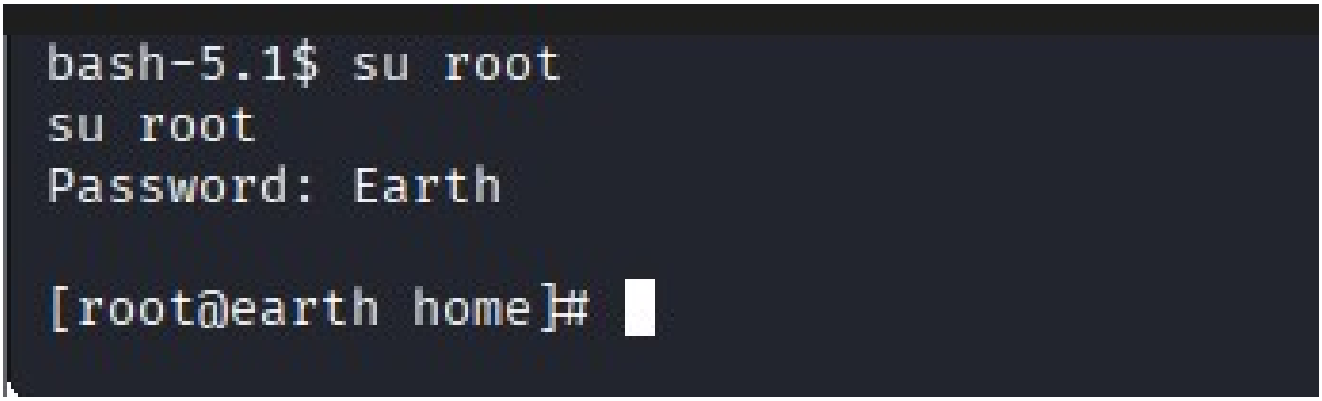
## Evidence P — Listener/session evidence; non-victim source details redacted.



### Evidence Q — reset_root trigger output showing root password reset.



**Evidence R — Successful root authentication in the lab.**



## Evidence S — Root flag access confirms root-level impact.

```
ls
anaconda-ks.cfg  root_flag.txt
[root@earth ~]# cat root_flag.txt
cat root_flag.txt

              _-o#&&*''''?d:>b\_
          _o/"`''  '',, dMF9MMMMMHo_
       .o&#'         `"MbHMMMMMMMMMMMHo.
     .o"" '         vodM*$&&HMMMMMMMMMM?.
    ,'              $M&ood,~'`(&##MMMMMMH\
   /                ,MMMMMM#b?#bobMMMMHMMML
  &              ?MMMMMMMMMMMMMMMMM7MMM$R*Hk
 ?$.            :MMMMMMMMMMMMMMMMMM/HMMM|`*L
|               |MMMMMMMMMMMMMMMMMMMbMH'   T,
$H#:            `*MMMMMMMMMMMMMMMMMMMb#}'  `?
]MMH#             ""*""""*#MMMMMMMMMMMMM'    -
MMMMMb_                   |MMMMMMMMMMP'     :
HMMMMMMMHo                 `MMMMMMMMMT       .
?MMMMMMMMP                  9MMMMMMMM}       -
-?MMMMMMM                   |MMMMMMMMM?,d-    '
 :|MMMMMM-                  `MMMMMMMT .M|.   :
  .9MMM[                    &MMMMM*' `'    .
   :9MMk                    `MMM#"        -
     &M}                     `          .-
      `&.                             .
        `~,   .                     ./
           . _                    .-
             '`--._,dd###pp=""'

Congratulations on completing Earth!
If you have any feedback please contact me at SirFlash@protonmail.com
[root_flag_b0da9554d29db2117b02aa8b66ec492e]
[root@earth ~]#
```